

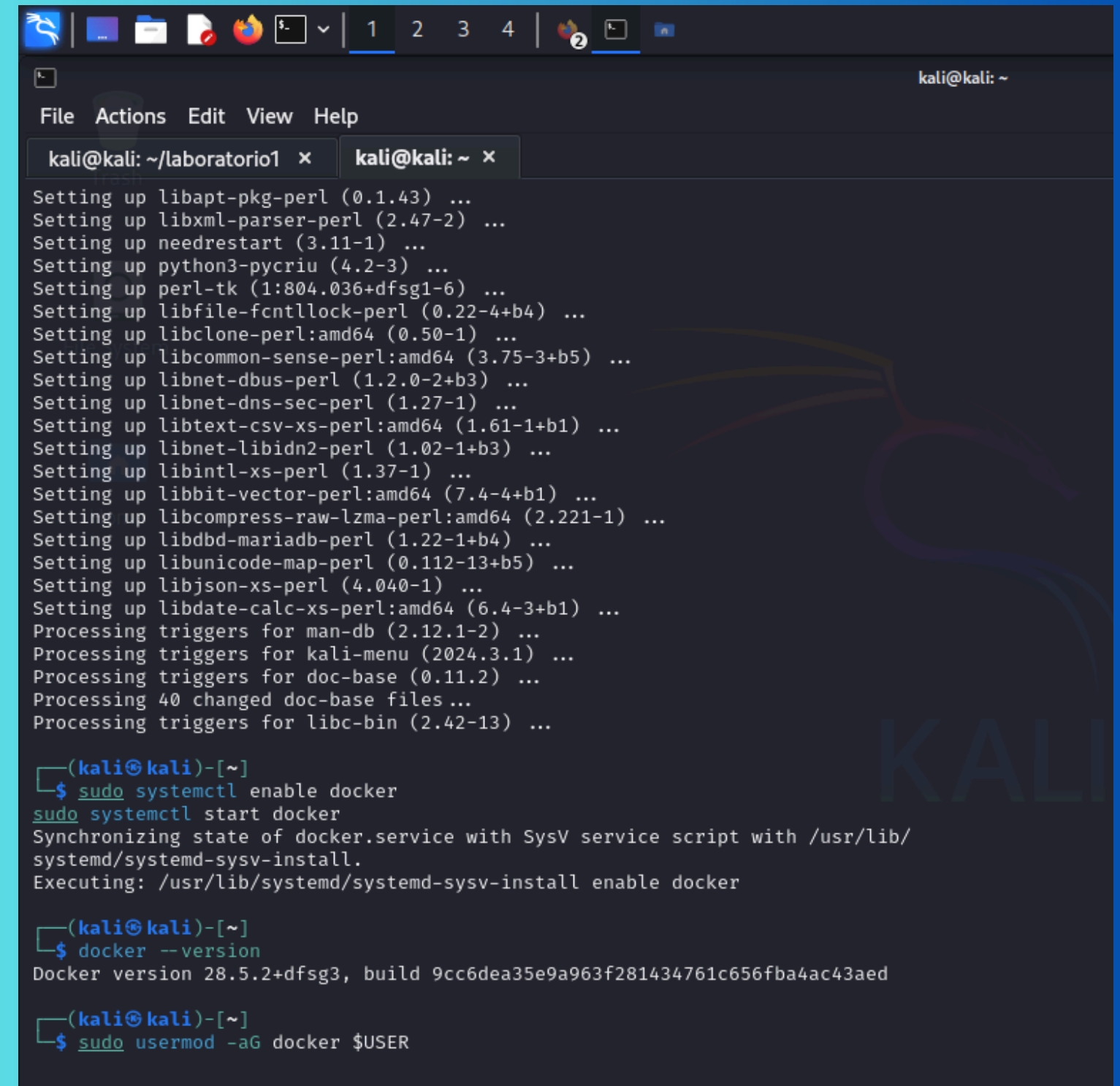
CIBERSEGURIDAD

Ataque de Fuerza Bruta SSH y Protección con
MFA

ARQUITECTURA DEL ENTORNO

Configuración del Laboratorio

Dos máquinas virtuales: Atacante (Kali Linux) y Víctima (Ubuntu Server), conectadas en red mediante Docker. La simulación controlada permite realizar pruebas de seguridad sin riesgos reales.



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~/laboratorio1 x kali@kali: ~ x  
Setting up libapt-pkg-perl (0.1.43) ...  
Setting up libxml-parser-perl (2.47-2) ...  
Setting up needrestart (3.11-1) ...  
Setting up python3-pycriu (4.2-3) ...  
Setting up perl-tk (1:804.036+dfsg1-6) ...  
Setting up libfile-fcntllock-perl (0.22-4+b4) ...  
Setting up libclone-perl:amd64 (0.50-1) ...  
Setting up libcommon-sense-perl:amd64 (3.75-3+b5) ...  
Setting up libnet-dbus-perl (1.2.0-2+b3) ...  
Setting up libnet-dns-sec-perl (1.27-1) ...  
Setting up libtext-csv-xs-perl:amd64 (1.61-1+b1) ...  
Setting up libnet-libidn2-perl (1.02-1+b3) ...  
Setting up libintl-xs-perl (1.37-1) ...  
Setting up libbit-vector-perl:amd64 (7.4-4+b1) ...  
Setting up libcompress-raw-lzma-perl:amd64 (2.221-1) ...  
Setting up libdbd-mariadb-perl (1.22-1+b4) ...  
Setting up libunicode-map-perl (0.112-13+b5) ...  
Setting up libjson-xs-perl (4.040-1) ...  
Setting up libdate-calc-xs-perl:amd64 (6.4-3+b1) ...  
Processing triggers for man-db (2.12.1-2) ...  
Processing triggers for kali-menu (2024.3.1) ...  
Processing triggers for doc-base (0.11.2) ...  
Processing 40 changed doc-base files ...  
Processing triggers for libc-bin (2.42-13) ...  
  
(kali@kali)-[~]  
$ sudo systemctl enable docker  
sudo systemctl start docker  
Synchronizing state of docker.service with SysV service script with /usr/lib/  
systemd/systemd-sysv-install.  
Executing: /usr/lib/systemd/systemd-sysv-install enable docker  
  
(kali@kali)-[~]  
$ docker --version  
Docker version 28.5.2+dfsg3, build 9cc6dea35e9a963f281434761c656fba4ac43aed  
  
(kali@kali)-[~]  
$ sudo usermod -aG docker $USER
```

Contenedor víctima

```
File Actions Edit View Help
kali@kali: ~/laboratorio1 x root@2618ae0292c0: / x

(kali@kali)-[~/laboratorio1]
$ docker ps
permission denied while trying to connect to the Docker daemon socket at unix:
:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.51/containers/json": dial unix /var/run/docker.sock: connect: permission denied

(kali@kali)-[~/laboratorio1]
$ newgrp docker

(kali@kali)-[~/laboratorio1]
$ docker network create lab-red
1dc12d2dc2b309451d1cd069c17206085fe715b5a66255c68312872aa17d6a31

(kali@kali)-[~/laboratorio1]
$ docker run -dit --name ubuntu-victima --network lab-red ubuntu:22.04
Unable to find image 'ubuntu:22.04' locally
22.04: Pulling from library/ubuntu
f63eb04151bc: Pull complete
Digest: sha256:962f6cadeae0ea6284001009daa4cc9a8c37e75d1f5191cf0eb83fe565b63d
d7
Status: Downloaded newer image for ubuntu:22.04
2618ae0292c014504849673212f13adee786f0bc9ebdf413b7d36864d57155a4

(kali@kali)-[~/laboratorio1]
$ docker exec -it ubuntu-victima bash
root@2618ae0292c0:/# apt update
apt install openssh-server sudo nano -y
Get:1 http://archive.ubuntu.com/ubuntu jammy InRelease [270 kB]
Get:2 http://security.ubuntu.com/ubuntu jammy-security InRelease [129 kB]
Get:3 http://security.ubuntu.com/ubuntu jammy-security/main amd64 Packages [3
863 kB]
Get:4 http://archive.ubuntu.com/ubuntu jammy-updates InRelease [128 kB]
Get:5 http://archive.ubuntu.com/ubuntu jammy-backports InRelease [127 kB]
Get:6 http://archive.ubuntu.com/ubuntu jammy/universe amd64 Packages [17.5 MB
]
Get:7 http://security.ubuntu.com/ubuntu jammy-security/multiverse amd64 Packa
ges [61.6 kB]
Get:8 http://security.ubuntu.com/ubuntu jammy-security/universe amd64 Package
s [1292 kB]
Get:9 http://security.ubuntu.com/ubuntu jammy-security/restricted amd64 Packa
```

```
File Actions Edit View Help
kali@kali: ~/laboratorio1 x root@2618ae0292c0: / x

Running hooks in /etc/ca-certificates/update.d ... done.
root@2618ae0292c0:/# mkdir /var/run/ssh
root@2618ae0292c0:/# nano /etc/ssh/sshd_config
root@2618ae0292c0:/# adduser usuario
Adding user `usuario' ...
Adding new group `usuario' (1000) ...
Adding new user `usuario' (1000) with group `usuario' ...
Creating home directory `/home/usuario' ...
Copying files from `/etc/skel' to `/home/usuario'
New password:
Retype new password:
Sorry, passwords do not match.
passwd: Authentication token manipulation error
passwd: password unchanged
Try again? [y/N] y
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for usuario
Enter the new value, or press ENTER for the default
Full Name []:
Room Number []:
Work Phone []:
Home Phone []:
Other []:
Is the information correct? [Y/n] y
root@2618ae0292c0:/# /usr/sbin/sshd
root@2618ae0292c0:/# hostname -I
172.18.0.2
root@2618ae0292c0:/#
```

5.1 Levantar contenedor

ChatGPT can make mistakes. Check important info.

Ataque de Dicionario

```
zsh: bad pattern: ^[[200~newgrp

(kali@kali)-[~/laboratorio1]
$ newgrp docker

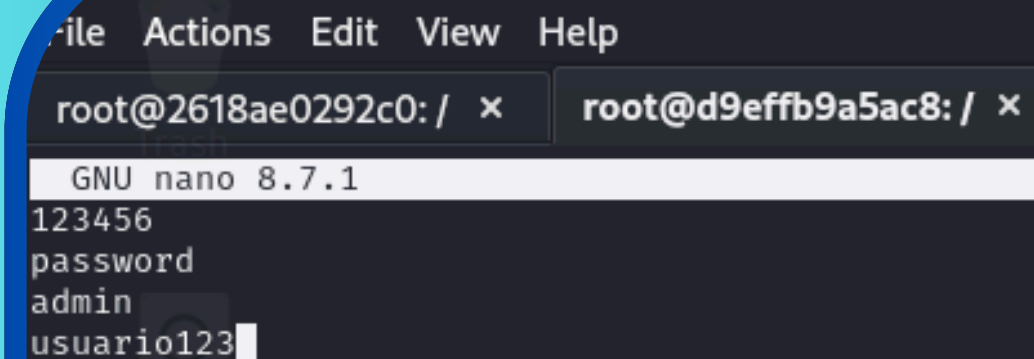
(kali@kali)-[~/laboratorio1]
$ docker run -dit --name kali-atacante --network lab-red kalilinux/kali-rolling
Unable to find image 'kalilinux/kali-rolling:latest' locally
latest: Pulling from kalilinux/kali-rolling
2b0c215c36c1: Pull complete
Digest: sha256:ab7f9873e9d976d62f59e172350604dd980339f567bfb2eaa5c2bdfaa2dc42b7
Status: Downloaded newer image for kalilinux/kali-rolling:latest
d9effb9a5ac8c2ec8eced6da4c8d06d0f16830137593b9628e2a2ca575e3c678

(kali@kali)-[~/laboratorio1]
$ docker exec -it kali-atacante bash
(root@d9effb9a5ac8)-[/]
# apt update
apt install hydra -y
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:3 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [15.3 kB]
Get:4 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Fetched 21.4 MB in 3s (7099 kB/s)
4 packages can be upgraded. Run 'apt list --upgradable' to see them.
Installing:
hydra
Installing dependencies:
bubblewrap libgsm1 libswscale9
ca-certificates libgssapi-krb5-2 libsymbd5
dbus libharfbuzz0b libsystemd-shared
dbus-bin libhashkit2t64 libtalloc2
dbus-daemon libheif-plugin-aomenc libtasn1-6
dbus-session-bus-common libheif-plugin-dav1d libtdb1
```

CONFIGURACIÓN DEL SERVIDOR VULNERABLE

Simulando Malas Prácticas

Servicio SSH activo en Ubuntu Server. Usuario con contraseña débil creado intencionalmente para demostrar vulnerabilidades. Las contraseñas poco seguras en accesos remotos representan un riesgo crítico de seguridad.



The screenshot shows a terminal window with two tabs. The active tab is titled 'root@d9effb9a5ac8: /'. The terminal content shows the prompt 'root@2618ae0292c0: /', followed by the command 'ssh root@2618ae0292c0', and then the output of the command: 'GNU nano 8.7.1', '123456', 'password', 'admin', and 'usuario123'. The cursor is positioned at the end of 'usuario123'.

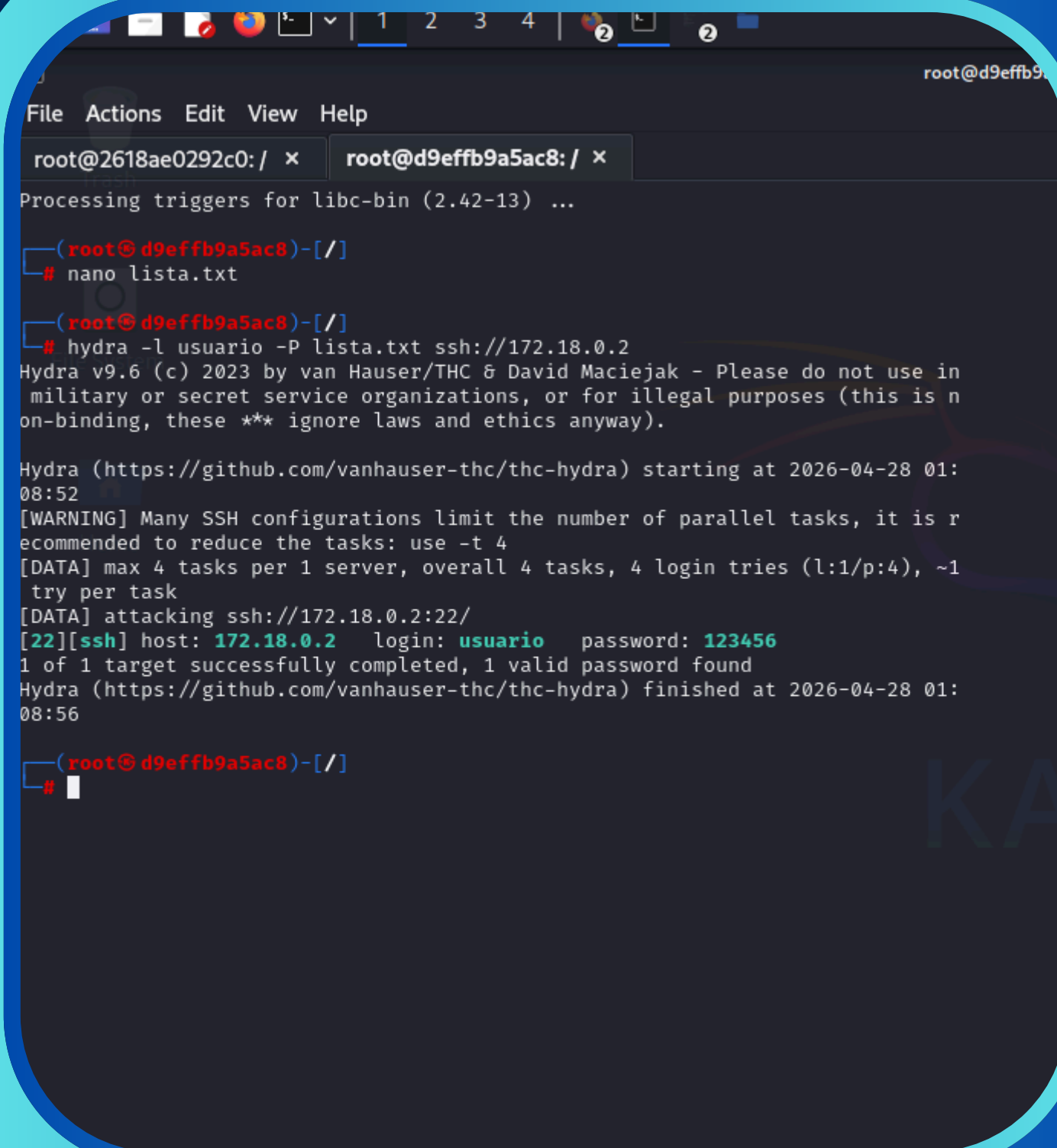
```
File Actions Edit View Help
root@2618ae0292c0: / x root@d9effb9a5ac8: / x
GNU nano 8.7.1
123456
password
admin
usuario123
```

EJECUCIÓN DEL ATAQUE CON HYDRA Y ACCESO EXITOSO AL SISTEMA

Demostración Práctica del Ataque

Hydra es una herramienta de fuerza bruta que automatiza pruebas de contraseñas contra servicios como SSH. Desde Kali Linux, ejecutamos el ataque contra el servidor Ubuntu, probando cada contraseña del diccionario hasta encontrar la correcta.

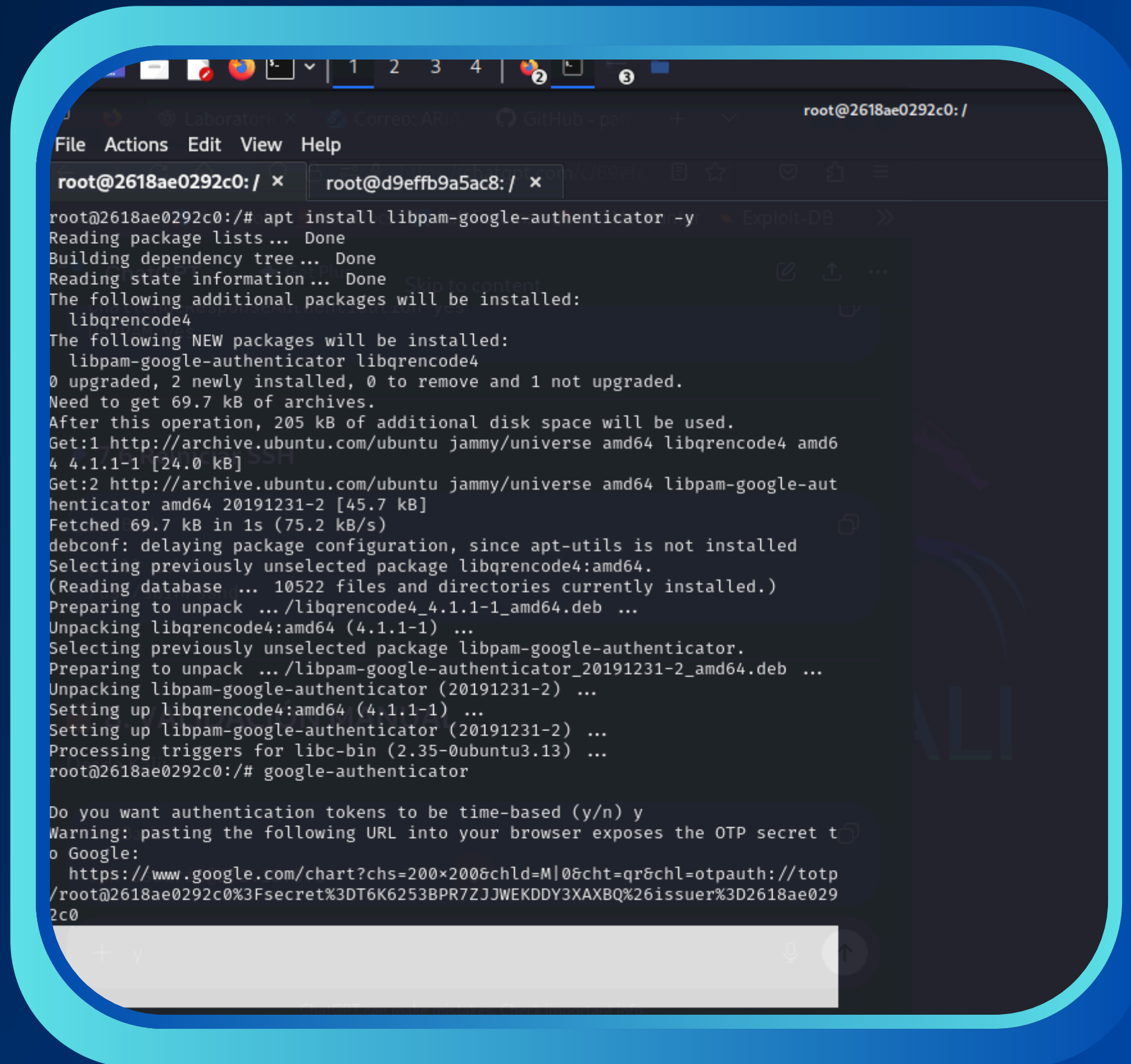
Login exitoso en Ubuntu Server usando las credenciales obtenidas por Hydra. Este acceso demuestra el impacto crítico de contraseñas débiles: un atacante tiene control total del sistema comprometido.

A screenshot of a terminal window with a dark background and light-colored text. The window title bar shows 'root@d9effb9a5ac8: /'. The terminal content shows the execution of Hydra. It starts with 'Processing triggers for libc-bin (2.42-13) ...'. Then, the user runs 'nano lista.txt'. Next, the user runs 'hydra -l usuario -P lista.txt ssh://172.18.0.2'. The output shows Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway). It then shows Hydra starting at 2026-04-28 01:08:52. A warning message states: '[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4'. A data line shows: '[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:1/p:4), ~1 try per task'. Another data line shows: '[DATA] attacking ssh://172.18.0.2:22/'. The final output shows: '[22][ssh] host: 172.18.0.2 login: usuario password: 123456'. It then states: '1 of 1 target successfully completed, 1 valid password found'. Finally, it shows Hydra finished at 2026-04-28 01:08:56. The prompt returns to the user: '(root@d9effb9a5ac8)-[/] # '.

IMPLEMENTACIÓN DE MFA

Autenticación Multifactor

MFA combina algo que sabes (contraseña) + algo que tienes (código temporal). Google Authenticator genera códigos de un solo uso que expiran cada 30 segundos, añadiendo una capa crítica de protección al acceso SSH.

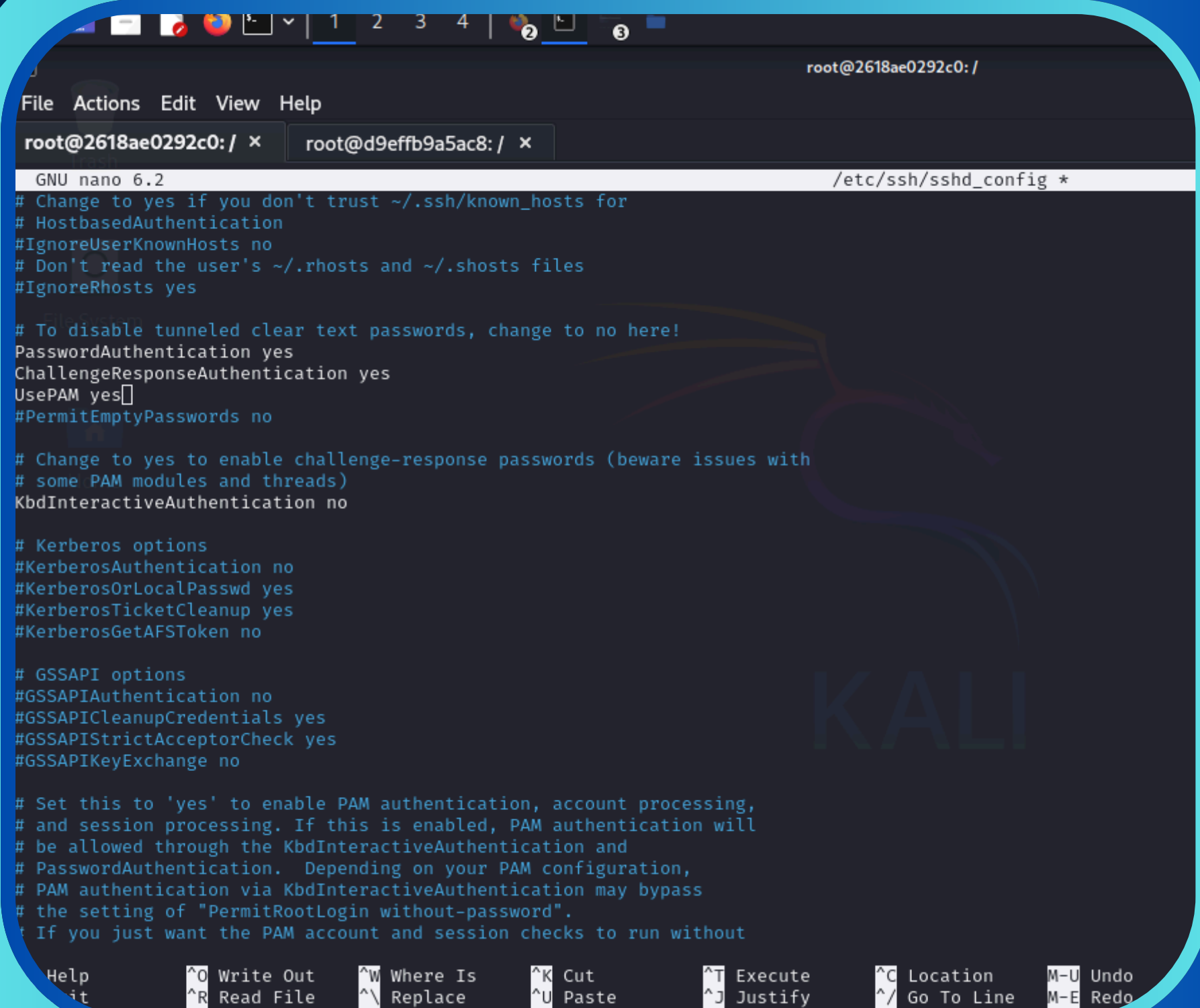


```
root@2618ae0292c0: /  
File Actions Edit View Help  
root@2618ae0292c0: / x root@d9effb9a5ac8: / x  
root@2618ae0292c0: /# apt install libpam-google-authenticator -y  
Reading package lists... Done  
Building dependency tree... Done  
Reading state information... Done  
The following additional packages will be installed:  
  libqrencode4  
The following NEW packages will be installed:  
  libpam-google-authenticator libqrencode4  
0 upgraded, 2 newly installed, 0 to remove and 1 not upgraded.  
Need to get 69.7 kB of archives.  
After this operation, 205 kB of additional disk space will be used.  
Get:1 http://archive.ubuntu.com/ubuntu jammy/universe amd64 libqrencode4 amd64 4.1.1-1 [24.0 kB]  
Get:2 http://archive.ubuntu.com/ubuntu jammy/universe amd64 libpam-google-authenticator amd64 20191231-2 [45.7 kB]  
Fetched 69.7 kB in 1s (75.2 kB/s)  
debconf: delaying package configuration, since apt-utils is not installed  
Selecting previously unselected package libqrencode4:amd64.  
(Reading database ... 10522 files and directories currently installed.)  
Preparing to unpack .../libqrencode4_4.1.1-1_amd64.deb ...  
Unpacking libqrencode4:amd64 (4.1.1-1) ...  
Selecting previously unselected package libpam-google-authenticator.  
Preparing to unpack .../libpam-google-authenticator_20191231-2_amd64.deb ...  
Unpacking libpam-google-authenticator (20191231-2) ...  
Setting up libqrencode4:amd64 (4.1.1-1) ...  
Setting up libpam-google-authenticator (20191231-2) ...  
Processing triggers for libc-bin (2.35-0ubuntu3.13) ...  
root@2618ae0292c0: /# google-authenticator  
  
Do you want authentication tokens to be time-based (y/n) y  
Warning: pasting the following URL into your browser exposes the OTP secret to Google:  
https://www.google.com/chart?chs=200x200&chld=M|0&cht=qr&chl=otpauth://totp/  
root@2618ae0292c0: /#  
root@2618ae0292c0: /#
```

INTEGRACIÓN CON SSH

Configuración Técnica de MFA

Modificación del servidor para solicitar: contraseña del usuario y código temporal generado en la app móvil. Ajustes en `/etc/pam.d/sshd` y `/etc/ssh/sshd_config` para habilitar autenticación de dos factores.

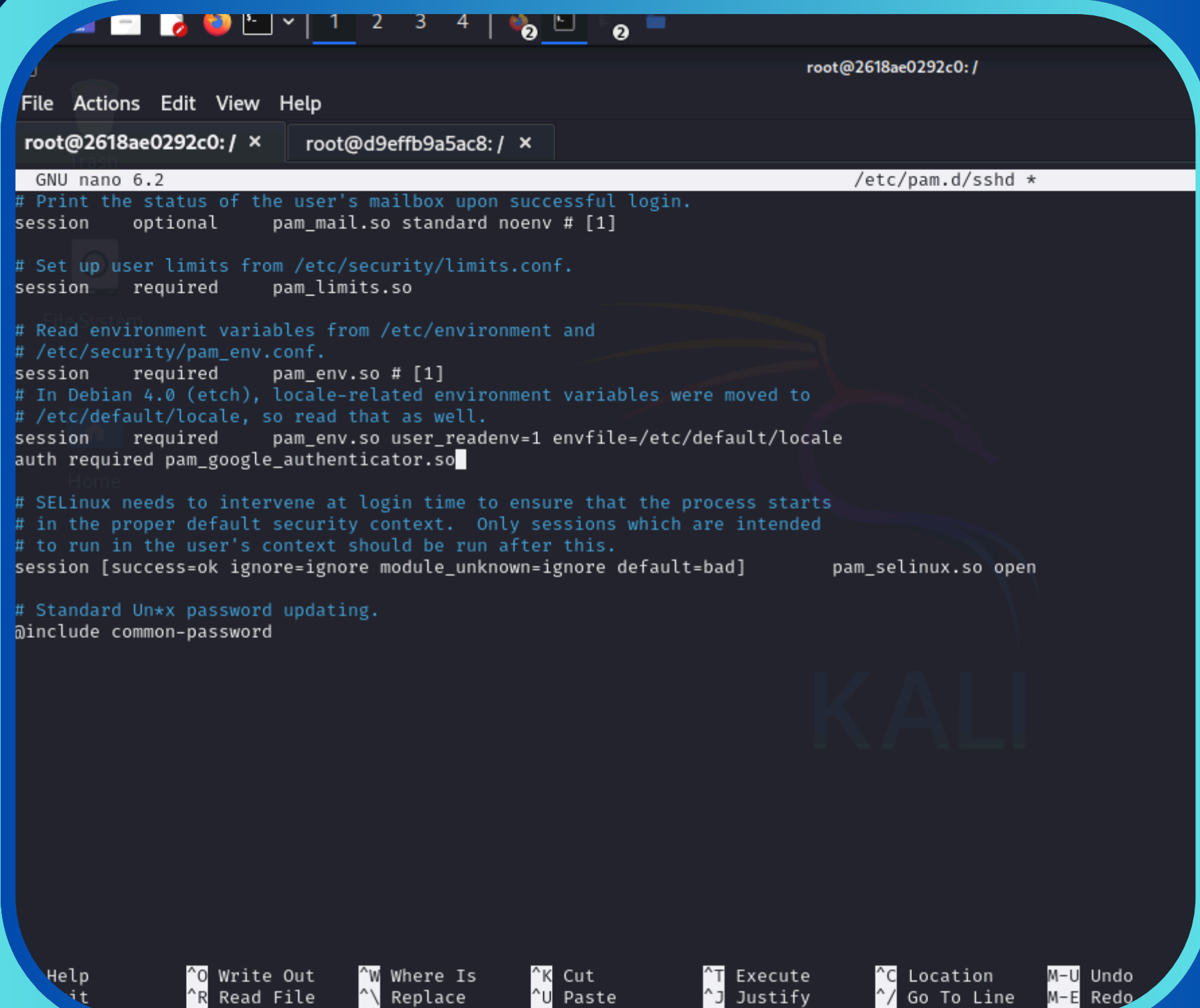


```
root@2618ae0292c0: /  
File Actions Edit View Help  
root@2618ae0292c0: / x root@d9effb9a5ac8: / x  
GNU nano 6.2 /etc/ssh/sshd_config *  
# Change to yes if you don't trust ~/.ssh/known_hosts for  
# HostbasedAuthentication  
#IgnoreUserKnownHosts no  
# Don't read the user's ~/.rhosts and ~/.shosts files  
#IgnoreRhosts yes  
  
# To disable tunneled clear text passwords, change to no here!  
PasswordAuthentication yes  
ChallengeResponseAuthentication yes  
UsePAM yes  
#PermitEmptyPasswords no  
  
# Change to yes to enable challenge-response passwords (beware issues with  
# some PAM modules and threads)  
KbdInteractiveAuthentication no  
  
# Kerberos options  
#KerberosAuthentication no  
#KerberosOrLocalPasswd yes  
#KerberosTicketCleanup yes  
#KerberosGetAFSToken no  
  
# GSSAPI options  
#GSSAPIAuthentication no  
#GSSAPICleanupCredentials yes  
#GSSAPIStrictAcceptorCheck yes  
#GSSAPIKeyExchange no  
  
# Set this to 'yes' to enable PAM authentication, account processing,  
# and session processing. If this is enabled, PAM authentication will  
# be allowed through the KbdInteractiveAuthentication and  
# PasswordAuthentication. Depending on your PAM configuration,  
# PAM authentication via KbdInteractiveAuthentication may bypass  
# the setting of "PermitRootLogin without-password".  
# If you just want the PAM account and session checks to run without
```


INTEGRACIÓN PAM

Configuración Técnica de MFA

Modificación del servidor para solicitar: contraseña del usuario y código temporal generado en la app móvil. Ajustes en `/etc/pam.d/sshd` y `/etc/ssh/sshd_config` para habilitar autenticación de dos factores.



```
File Actions Edit View Help
root@2618ae0292c0: / x root@d9effb9a5ac8: / x
GNU nano 6.2 /etc/pam.d/sshd *
# Print the status of the user's mailbox upon successful login.
session optional pam_mail.so standard noenv # [1]

# Set up user limits from /etc/security/limits.conf.
session required pam_limits.so

# Read environment variables from /etc/environment and
# /etc/security/pam_env.conf.
session required pam_env.so # [1]
# In Debian 4.0 (etch), locale-related environment variables were moved to
# /etc/default/locale, so read that as well.
session required pam_env.so user_readenv=1 envfile=/etc/default/locale
auth required pam_google_authenticator.so

# SELinux needs to intervene at login time to ensure that the process starts
# in the proper default security context. Only sessions which are intended
# to run in the user's context should be run after this.
session [success=ok ignore=ignore module_unknown=ignore default=bad] pam_selinux.so open

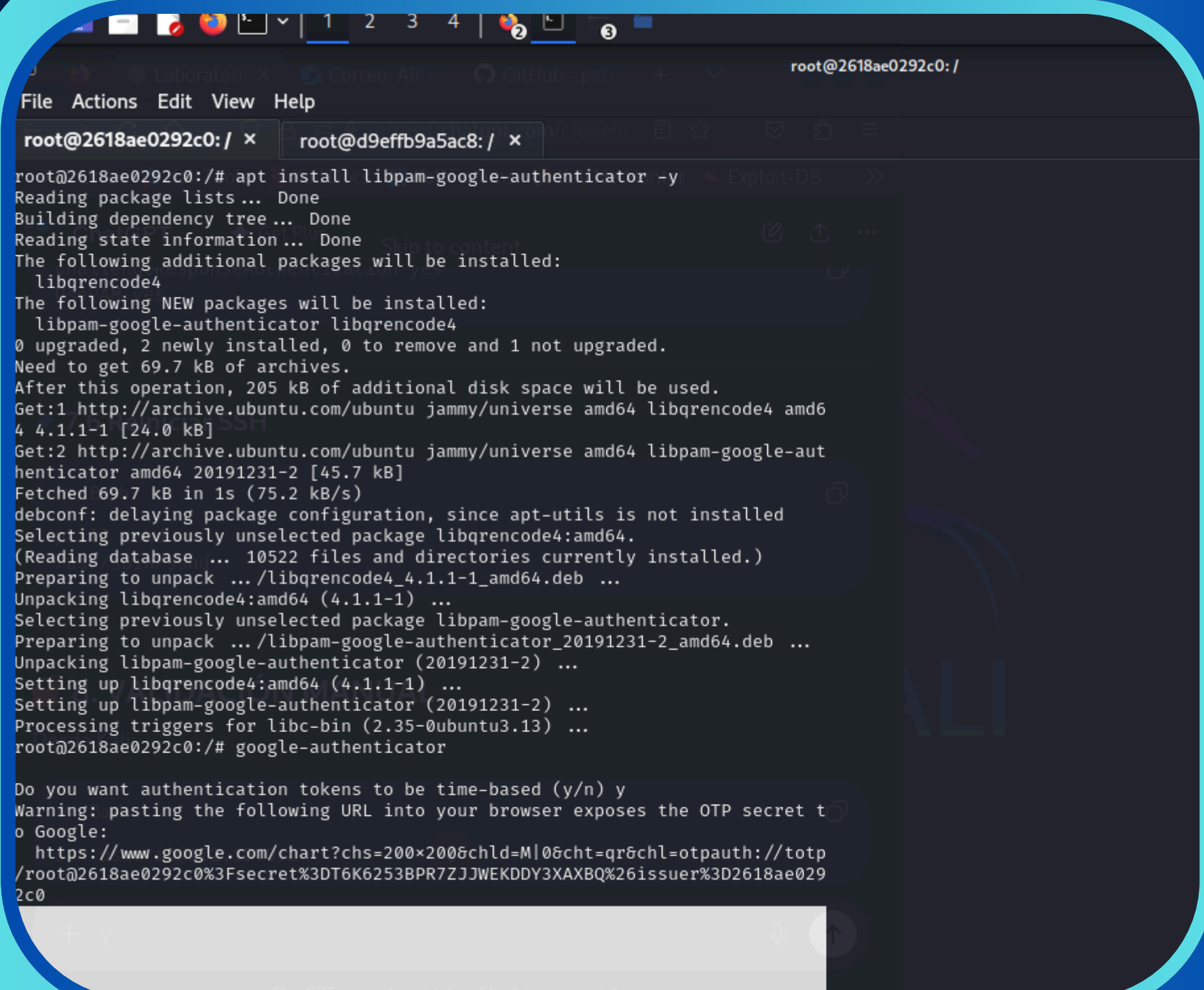
# Standard Unix password updating.
@include common-password

Help Write Out Where Is Cut Execute Location M-U Undo
it Read File Replace Paste Justify Go To Line M-E Redo
```

VALIDACIÓN DEL ACCESO CON MFA

Confirmación del Nuevo Proceso

El login ahora requiere contraseña y código generado en el celular. Esta doble verificación proporciona mayor protección contra accesos no autorizados, incluso si la contraseña es comprometida.



```
root@2618ae0292c0: /  
File Actions Edit View Help  
root@2618ae0292c0: / x root@d9effb9a5ac8: / x  
root@2618ae0292c0: /# apt install libpam-google-authenticator -y  
Reading package lists... Done  
Building dependency tree... Done  
Reading state information... Done  
The following additional packages will be installed:  
  libqrencode4  
The following NEW packages will be installed:  
  libpam-google-authenticator libqrencode4  
0 upgraded, 2 newly installed, 0 to remove and 1 not upgraded.  
Need to get 69.7 kB of archives.  
After this operation, 205 kB of additional disk space will be used.  
Get:1 http://archive.ubuntu.com/ubuntu jammy/universe amd64 libqrencode4 amd64 4.1.1-1 [24.0 kB]  
Get:2 http://archive.ubuntu.com/ubuntu jammy/universe amd64 libpam-google-authenticator amd64 20191231-2 [45.7 kB]  
Fetched 69.7 kB in 1s (75.2 kB/s)  
debconf: delaying package configuration, since apt-utils is not installed  
Selecting previously unselected package libqrencode4:amd64.  
(Reading database ... 10522 files and directories currently installed.)  
Preparing to unpack .../libqrencode4_4.1.1-1_amd64.deb ...  
Unpacking libqrencode4:amd64 (4.1.1-1) ...  
Selecting previously unselected package libpam-google-authenticator.  
Preparing to unpack .../libpam-google-authenticator_20191231-2_amd64.deb ...  
Unpacking libpam-google-authenticator (20191231-2) ...  
Setting up libqrencode4:amd64 (4.1.1-1) ...  
Setting up libpam-google-authenticator (20191231-2) ...  
Processing triggers for libc-bin (2.35-0ubuntu3.13) ...  
root@2618ae0292c0: /# google-authenticator  
  
Do you want authentication tokens to be time-based (y/n) y  
Warning: pasting the following URL into your browser exposes the OTP secret to Google:  
https://www.google.com/chart?chs=200x200&chld=M|0&cht=qr&chl=otpauth://totp/  
root@2618ae0292c0: /#
```

REPETICIÓN DEL ATAQUE

MFA Detiene el Ataque

Hydra encuentra la contraseña nuevamente, pero no logra autenticarse sin el código temporal. El atacante queda bloqueado incluso con credenciales válidas, demostrando la efectividad de MFA.

```
File Actions Edit View Help
root@d9effb9a5ac8: /
root@2618ae0292c0: / x root@d9effb9a5ac8: / x
(usuario@172.18.0.2) Verification code:
(usuario@172.18.0.2) Password:
(usuario@172.18.0.2) Verification code:
usuario@172.18.0.2's password:
Connection closed by 172.18.0.2 port 22

(root@d9effb9a5ac8)-[/]
# hydra -l usuario -P lista.txt ssh://172.18.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-28 01:
34:02
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:1/p:4), ~1
try per task
[DATA] attacking ssh://172.18.0.2:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-28 01:
34:05

(root@d9effb9a5ac8)-[/]
#
```